

Roteiro de Apresentação: Dossiê Técnico de Segurança em Dispositivos IoT

1. Abertura e Contextualização Impactante

A Internet das Coisas (IoT) transcendeu a automação de nicho para se tornar a infraestrutura invisível da sociedade moderna. Segundo dados da *IoT Analytics*, o ecossistema atingirá a marca de **~21,1 bilhões de dispositivos conectados em 2025**, com projeções escalando para **39 bilhões até 2030**. Esse crescimento não é meramente quantitativo; ele representa uma massiva **expansão da superfície de ataque**. Cada novo nó — seja um sensor de umidade no campo ou um marcapasso em um hospital — amplia o perímetro que defensores devem proteger e atacantes podem explorar.

Identificação do Repositório: IoT Knowledge Hub

- **Instituição:** Instituto de Informática — Universidade Federal de Goiás (UFG)
 - **Disciplina:** Internet das Coisas (Engenharia de Computação)
 - **Período:** 2026/3 (Férias de Inverno)
 - **Autor:** Higor Ferreira Silva
 - **Propósito:** Base de conhecimento acadêmica para suporte a seminários e monitorias.
- Nota para o Orador:** Inicie com a analogia da **"jornada de uma lâmpada inteligente"**. Explique que o ato trivial de acender uma luz via smartphone atravessa o hardware do dispositivo, a pilha de protocolos Wi-Fi, o gateway doméstico, APIs de terceiros e servidores em nuvem. Cada salto é um ponto de vulnerabilidade; uma falha em qualquer elo compromete a integridade de todo o sistema.

2. Parte I: Fundamentos da Segurança — O Alicerce da Confiança

IoT vs. IIoT: Prioridades e o Desafio da Longevidade

Diferenciar IoT (Consumidor) de IIoT (Industrial) é o primeiro passo para o especialista. Enquanto o consumidor prioriza conveniência, a indústria exige resiliência absoluta.

	IoT (Consumidor)	IIoT (Industrial)
Prioridade Principal	Conforto e Automação	Disponibilidade e Segurança Operacional
Impacto de Falha	Inconveniência (ex: luz não acende)	Acidente crítico / Prejuízo financeiro e ambiental
Vida Útil	Curta (2 a 5 anos) Longa (20 a 30 anos)	
Segurança	Frequentemente "Best Effort"	Requisito rigoroso (Safety + Security)

Insight do Especialista: A vida útil de 30 anos em ambientes industriais cria um abismo tecnológico. Dispositivos instalados hoje deverão resistir a ameaças de 2050, o que torna o gerenciamento de patches e a criptografia ágil desafios monumentais comparados ao ciclo de 2 anos de um smartphone.

Segurança no Silício: A Raiz de Confiança (RoT)

Se o hardware for comprometido, nenhuma camada superior de software é confiável.

- **Root of Trust (RoT):** Funciona como o **"cartório"** do silício. É a base mínima, imutável e protegida que garante a identidade do chip.

- **Secure Boot:** Processo que verifica assinaturas digitais antes de carregar o firmware, garantindo que apenas código autêntico seja executado.
- **eFuses:** Registradores permanentes. Uma vez "queimados", travam fisicamente configurações de segurança (como o Secure Boot), impedindo retrocessos (*rollbacks*).
- **Flash Encryption:** Protege o firmware contra leitura direta e engenharia reversa caso o atacante obtenha acesso físico ao chip.
- **ARM TrustZone:** Isolamento por hardware que separa o sistema em "Mundo Seguro" (operações sensíveis) e "Mundo Normal".

Protocolos e a Tríade CIA

A comunicação IoT exige protocolos leves que mantenham a Confidencialidade, Integridade e Autenticidade (CIA).| Protocolo | Transporte | Mecanismos de Segurança || ----- | ----- | ----- || **MQTT** | TCP | Depende de TLS 1.3 (RFC 8446) para criptografia e mTLS para autenticação mútua. || **CoAP** | UDP | Utiliza DTLS ou **OSCORE** (RFC 8613) para proteger o conteúdo da mensagem em nível de objeto. |

3. Parte II: Ambientes e Vetores de Ataque — Teoria e Ameaça

Convergência TI/OT e o Fim do Air Gap

Historicamente, sistemas industriais eram isolados (*air gap*). Hoje, a Indústria 4.0 exige que o PLC (Controlador Lógico Programável) fale com a Nuvem. É vital distinguir **Safety** (Segurança Funcional: prevenção de acidentes e proteção da vida) de **Security** (Proteção contra atos intencionais de atacantes). Em IIoT, uma falha de *Security* pode anular os mecanismos de *Safety*. **Modelo Purdue (Níveis de Defesa):**

1. **Nível 0:** Processo físico (sensores e atuadores).
2. **Nível 1:** Controle básico (PLCs, RTUs).
3. **Nível 2:** Supervisão de área (SCADA, IHMs).
4. **Nível 3:** Operações de manufatura (Historian, MES).
5. **Nível 3.5 (DMZ Industrial):** Camada vital onde firewalls inspecionam o tráfego que transita entre a rede industrial e a corporativa.
6. **Nível 4/5:** Rede corporativa e Internet.

Modelagem STRIDE e Ataques Reais

O modelo STRIDE mapeia como as ameaças violam propriedades fundamentais.| Ameaça | Propriedade Violada | Exemplo em IoT || ----- | ----- | ----- || **Spoofing** | Autenticidade | Um sensor falso injetando dados na rede. || **Tampering** | Integridade | Alteração do firmware via atualização não assinada. || **Repudiation** | Não Repúdio | Atacante deletando logs para negar a invasão. || **Info Disclosure** | Confidencialidade | Interceptação de dados sensíveis em texto claro. || **Denial of Service** | Disponibilidade | Botnet Mirai sobrecarregando um broker MQTT. || **Elevation of Privilege** | Autorização | Usuário comum ganhando permissões de *root* . |

Marcos Históricos:

- **Mirai (2016):** Botnet que explorou senhas padrão para derrubar a infraestrutura de DNS da Dyn.

- **Stuxnet:** Demonstrou que malwares podem cruzar o *air gap* via USB para destruir fisicamente centrífugas industriais.

Backend IoT e Observabilidade

A segurança do backend é onde a maioria das falhas de escala ocorre.

1. **BOLA (Broken Object Level Authorization):** Vulnerabilidade **#1 do OWASP API Security Top 10** . Ocorre quando a API falha ao validar se o usuário autenticado tem permissão para acessar um ID de objeto específico de outro usuário.
2. **Digital Twin:** Representação virtual do ativo físico. Implementado como **Device Shadows** (AWS IoT Core) ou **Device Twins** (Azure IoT Hub) para gerenciar estados *online/offline* .
3. **Pilares da Observabilidade:**
4. **Logs:** Registros discretos de eventos ocorridos.
5. **Métricas:** Dados agregados e mensuráveis ao longo do tempo (ex: CPU, latência).
6. **Traces:** Rastreamento de ponta a ponta do fluxo de uma requisição entre microsserviços.

4. Parte III: Ciclo de Vida e Governança

O Ciclo de Vida Seguro

A segurança deve ser **Secure by Design** (planejada no projeto) e **Secure by Default** (segura em sua configuração de fábrica).

- **SBOM (Software Bill of Materials):** Inventário crítico de componentes. O caso **Ripple20** mostrou o perigo de vulnerabilidades na pilha TCP/IP da **Treck** , que afetou milhões de dispositivos devido à falta de visibilidade sobre dependências de terceiros.
- **Descomissionamento:** Uso de **Cryptographic Erase** — apagar as chaves de descryptografia da RoT torna os dados remanescentes na Flash permanentemente ilegíveis.

Normas e Legislação Internacional

- **NIST CSF 2.0:** Foco na governança e gestão de riscos.
- **ISA/IEC 62443:** O padrão internacional para cibersegurança industrial (OT).
- **Cyber Resilience Act (CRA - UE):** Impacto global para fabricantes.
- **11 de Setembro de 2026:** Início da obrigatoriedade de notificação de vulnerabilidades.
- **11 de Dezembro de 2027:** Implementação das obrigações principais de conformidade.
- **LGPD:** Aplicação brasileira para proteção de dados pessoais coletados por IoT.

Prioridades por Cenário

Cenário, Prioridade Principal, Maior Risco

Smart Home, Privacidade, Invasão e espionagem (Câmeras IP).

Hospital, Disponibilidade (Safety), Interrupção de bombas de infusão (Risco à vida).

Indústria 4.0, Continuidade Operacional, Ransomware paralisando a linha de produção.

5. Metodologia de Uso e Analogias Didáticas

Utilize estas analogias para simplificar a transmissão do conhecimento:

- **Root of Trust = Certidão de Nascimento:** O documento base que prova que você é você.
- **Certificado Digital = Passaporte:** Documento aceito internacionalmente para cruzar fronteiras.
- **TLS = Envelope Lacrado:** Todos veem que algo foi enviado, mas apenas o destinatário lê o conteúdo.
- **Secure Boot = Lacre de Medicamento:** Se o lacre estiver rompido, não consuma (não execute o código).

Checklist para Apresentação

- Explicou por que a vida útil industrial (30 anos) dificulta o *patching* ?
- Mapeou o STRIDE às propriedades violadas?
- Apresentou a DMZ Industrial (Nível 3.5 do Purdue)?
- Citou a vulnerabilidade BOLA como o risco #1 em APIs?
- Diferenciou explicitamente *Safety* de *Security* ?

6. Conclusão Reflexiva: O Futuro da Segurança IoT

A segurança não é um produto estático, mas um processo contínuo de mitigação. O futuro aponta para o colapso do perímetro tradicional. A arquitetura **Zero Trust** ("nunca confie, sempre verifique") desafia o Modelo Purdue, exigindo que cada sensor seja autenticado e verificado individualmente, independente de sua localização na rede. Com tecnologias emergentes como **IA** e **Edge Analytics**, a capacidade de detectar anomalias em tempo real aumentará, mas o profissional de Engenharia de Computação deve manter o foco no alicerce: hardware seguro, autenticação forte e transparência total na cadeia de suprimentos de software.

7. Referências e Encerramento Técnico

Referências Normativas e Técnicas

- **NIST CSF 2.0 / IR 8259:** Gestão de riscos e requisitos para fabricantes.
- **ISA/IEC 62443:** Segurança para automação e sistemas de controle industrial.
- **IETF RFC 8446:** Especificação do protocolo TLS 1.3.
- **IETF RFC 7252 / RFC 8613:** Protocolo CoAP e extensão OSCORE.
- **Cyber Resilience Act:** Regulamento (UE) 2024/2847.
- **OWASP API Security Top 10 (2023):** Referência para segurança de backends. **Autor:** Higor Ferreira Silva **Instituição:** Instituto de Informática — Universidade Federal de Goiás (UFG)